

ZAP by Checkmarx Scanning Report

Generated with  ZAP on Wed 20 May 2026, at 17:11:00

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Contents

1. [About This Report](#)
 1. [Report Parameters](#)
2. [Summaries](#)
 1. [Alert Counts by Risk and Confidence](#)
 2. [Alert Counts by Site and Risk](#)
 3. [Alert Counts by Alert Type](#)
 4. [Insights](#)
3. [Alerts](#)
 1. [Risk=Medium, Confidence=High \(1\)](#)
 2. [Risk=Medium, Confidence=Medium \(1\)](#)
 3. [Risk=Low, Confidence=High \(2\)](#)
 4. [Risk=Low, Confidence=Low \(1\)](#)
 5. [Risk=Informational, Confidence=Medium \(1\)](#)
 6. [Risk=Informational, Confidence=Low \(1\)](#)
4. [Appendix](#)
 1. [Alert Types](#)

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

https://demo.owasp-juice.shop

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: High, Medium, Low, Informational

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User				
		Confirmed	High	Medium	Low	Total
Risk	High	0	0	0	0	0
		(0.0%)	(0.0%)	(0.0%)	(0.0%)	(0.0%)

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence			
		User			
		High	Medium	Low	Total
Confirmed					
	0	1	1	0	2
Medium					
	(0.0%)	(14.3%)	(14.3%)	(0.0%)	(28.6%)
Low	0	2	0	1	3
	(0.0%)	(28.6%)	(0.0%)	(14.3%)	(42.9%)
Informational	0	0	1	1	2
	(0.0%)	(0.0%)	(14.3%)	(14.3%)	(28.6%)
Total	0	3	2	2	7
	(0.0%)	(42.9%)	(28.6%)	(28.6%)	(100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

Risk

	High (=	Medium (>=	Low (>=	Informational (>=
High) Medium) Low) Informational)				
https://demo.owasp-	0	2	3	2
Site				
juice.shop	(0)	(2)	(5)	(7)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
<u>Content Security Policy (CSP) Header Not Set</u> (71.4%)	Medium	5
<u>Cross-Domain Misconfiguration</u> (71.4%)	Medium	5
<u>Server Leaks Version Information via "Server" HTTP Response Header Field</u> (42.9%)	Low	3
<u>Strict-Transport-Security Header Not Set</u> (71.4%)	Low	5
<u>Timestamp Disclosure - Unix</u> (71.4%)	Low	5
<u>Modern Web Application</u> (71.4%)	Informational	5
<u>Re-examine Cache-control Directives</u> (71.4%)	Informational	5
Total		7

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	1
Low	Warning		ZAP warnings logged - see the zap.log file for details	2
Info	Informational	https://demo.owasp-juice.shop	Percentage of responses with status code 2xx	97 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of responses with status code 4xx	2 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type application/javascript	9 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type application/octet-stream	3 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type image/x-icon	5 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type text/css	5 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type text/html	82 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type text/markdown	2 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with content type text/plain	5 %
Info	Informational	https://demo.owasp-juice.shop	Percentage of endpoints with method GET	100 %

Info Informational	https://demo.owasp-juice.shop	Count of total endpoints	136
Info Informational	https://demo.owasp-juice.shop	Percentage of slow responses	100 %

Alerts

1. Risk=Medium, Confidence=High (1)

1. https://demo.owasp-juice.shop (1)

1. Content Security Policy (CSP) Header Not Set (1)

1. GET
https://demo.owaspjuice.shop/sitemap.xml

- ▣ [OWASP_2021_A05](#)
- ▣ POLICY_QA_STD =
- ▣ POLICY_PENTEST =
- ▣ [SYSTEMIC](#)
- ▣ [CWE-693](#)
- ▣ [OWASP_2017_A06](#)
- ▣ [OWASP_2025_A02](#)

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including drive-by downloads, data theft, and site defacement. These attacks are used for everything from data theft to site defacement. CSP allows approved sources of content that browsers should be allowed to load Java applets, ActiveX, audio and video files.

Request line and header section (255 bytes)

```
GET https://demo.owasp-juice.shop/sitemap.xml host: demo.owasp-juice.shop user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) pragma: no-cache cache-control: no-cache
```

Request body (0 bytes)

Status line and header section (971 bytes)

```
HTTP/1.1 200 OK
Date: Wed, 20 May 2026 12:09:18 GMT
Server: Heroku
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Length: 9903
Content-Type: text/html; charset=UTF-8
Etag: W/"26af-19e453eb22f"
Feature-Policy: payment 'self'
Last-Modified: Wed, 20 May 2026 11:56:37 GMT
Nel: {"report_to":"heroku-nel","response_headers":Report-To:
```

```
{"group":"herokunel","endpoints":[{"url":"https://nel
.heroku. 0bd0-43b1-a5f1-
b25750382959\u0026ts=177927895 Reporting-Endpoints:
herokunel="https://nel.heroku.com/reports?s=vkEDFAI
b25750382959&ts=1779278958" Vary: Accept-
Encoding
```

```
Via: 1.1 heroku-router
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

Response body (9903 bytes)

```
<!--
```



```
~ SPDX-License-Identifier: MIT
-->
```

```
<!doctype html>
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably
  <meta name="viewport" content="width=device <link
    rel="preconnect" href="https://fonts.
  <link rel="preconnect" href="https://fonts.
<style>@font-face{font-family:'VT323';font
display:swap;src:url(https://fonts.gstatic.co
range:U+0102-0103, U+0110-0111, U+0128-0129, U+0323,
U+0329, U+1EA0-1EF9, U+20AB;}@font-fa
display:swap;src:url(https://fonts.gstatic.co
range:U+0100-02BA, U+02BD-02C5, U+02C7-02CC, U+1EF2-
1EFF, U+2020, U+20A0-20AB, U+20AD-20C
style:normal;font-weight:400;font-display:swa
format('woff2');unicode-range:U+0000-00FF, U
U+2000-206F, U+20AC, U+2122, U+2191, U+2193,
  <link id="favicon" rel="icon" type="image/x
  <script>
    window.addEventListener("load", function(
window.cookieconsent.initialise({
  "palette": {
    "popup": { "background": "var(--the
    "button": { "background": "var(--th
  },
  "theme": "classic",
  "position": "bottom-right",
    "content": { "message": "This website
    "dismiss": "Me want it!", "link": "But me wa
  }));
</script>
```

```
<style>.bluegrey-lightgreen-theme{--mat-sysmat-sys-
```

```
inverse-on-surface:#2f3033;--mat-sys
background:#e3e2e6;--mat-sys-on-error:#690005 on-
primary-container:#d7e3ff;--mat-sys-on-pri
secondary:#283041;--mat-sys-on-secondary-cont fixed-
variant:#3e4759;--mat-sys-on-surface:#e sys-on-
tertiary-container:#82ff10;--mat-sysoutline:#8e9099;
-mat-sys-outline-variant:#44 primary-fixed:#d7e3ff;--
mat-sys-primary-fixed secondary-container:#3e4759;--
mat-sys-seconda shadow:#000000;--mat-sys-
surface:#121316;--ma surface-container-high:#292a2c;-
-mat-sys-surf sys-surface-container-lowest:#0d0e11;--
mat-sy variant:#44474e;--mat-sys-tertiary:#70e000;-
tertiary-fixed-dim:#70e000;--mat-sys-neutral rgba(0,
0, 0, .2), 0px 0px 0px 0px rgba(0, 0, rgba(0, 0, 0,
.2), 0px 1px 1px 0px rgba(0, 0, rgba(0, 0, 0, .2),
0px 3px 4px 0px rgba(0, 0, rgba(0, 0, 0, .2), 0px 6px
10px 0px rgba(0, 3px rgba(0, 0, 0, .2), 0px 8px 10px
1px rgba -4px rgba(0, 0, 0, .2), 0px 12px 17px 2px
rgb large:28px;--mat-sys-corner-extra-large-top:2
top:4px 4px 0 0;--mat-sys-corner-full:9999px; corner-
large-start:16px 0 0 16px;--mat-sys-co none:0;--mat-
sys-corner-small:8px;--mat-syssys-hover-state-layer-
opacity:.08;--mat-syscolor:var(--mat-sys-
surface)}html{font-family serif)}.bluegrey-
lightgreen-theme{--theme-pri primary-light:rgb(118,
173.3829787234, 255); dark:rgb(16, 112.6170212766,
255);--theme-pri 30:#438fff;--theme-primary-fade-
40:#438fff;-lighter:rgb(94.9268292683, 194.6, 0);--
theme darker:rgb(65.0731707317, 133.4, 0);--
themeaccent-fade-20:#50a400;--theme-accent-fade-30
warn:#ffb4ab;--theme-warn-lighter:rgb(255, 20 warn-
darker:rgb(255, 152.6785714286, 140.4); theme-warn-
fade-20:#ffb4ab;--theme-warn-fade text:#e3e2e6;--
theme-text-lighter:rgb(242.866 253.3888888889,
253.6111111111);--theme-text dark:rgb(160.8888888889,
157.5277777778, 170. text-fade-30:#e3e2e6;--theme-
text-fade-40:#e 199.25);--theme-text-invert-
30:rgb(167.3, 166 lighter:rgb(45.5938461538,
47.0646153846, 50. 60.6769230769);--theme-background-
darker:rgb( dark:rgb(6.6769230769, 6.8923076923,
7.323076 theme-thumbnail-border:1px solid #abc7ff;--
md container-color:#0000;--theme-background:#3e3
theme-background-darker:#333638;--theme-backg theme-
text-lighter:#f2f5f7;--theme-text-light
surface:#333638;--mat-sys-on-surface:#e8ecef; mat-
sys-on-surface-variant:#b8c0c7;--mat-sys theme-
warn:#f44336;--theme-warn-lighter:rgb(2
light:rgb(246.6462264151, 112.2264150943, 102
24.9877358491);--theme-warn-dark:rgb(234.1839 warn-
```

```

fade-20:#f44336;--theme-warn-fade-30:#f
error:#f44336;--mat-sys-on-error:#fff}@media
href="styles.css" media="print" onload="this.
href="styles.css"></noscript></head>
<body class="bluegrey-lightgreen-theme">
  <app-root></app-root>
<link      rel="modulepreload"      href="chunk-SCY7Y0
rel="modulepreload"      href="chunk-GNBEOV4E.js"
href="chunk-JCQ5N7PA.js"><link      rel="modulepre
524KQQJQ.js"><link rel="modulepreload" href="
rel="modulepreload" href="chunk-7AKA75AX.js"
defer></script><script src="main.js" type="mo
</html>

```

Ensure that your web server, application server, load balancer, etc.

2. Risk=Medium,

Confidence=Medium (1)

1. <https://demo.owasp-juice.shop> (1)

1. Cross-Domain Misconfiguration (1)

1. GET <https://demo.owasp-juice.shop/chunk703TTE7G.js>

Content-Type: application/javascript;
charset=
Etag: W/"a0f4-19e1c1166b8"
Feature-Policy: payment 'self'
Last-Modified: Tue, 12 May 2026 12:02:43 GMT
Nel: {"report_to":"heroku-nel","response_headers":
Report-To: {"group":"heroku-nel","endpoints":
b25750382959\u0026ts=1779278959"}}, {"max_age":3
Reporting-Endpoints: heroku-nel="https://nel.h
Vary: Accept-Encoding
Via: 1.1 heroku-router
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs

Response body (41204 bytes)

```
import{a as xe}from"./chunk-  
ZO2KHBRB.js";impor as C,Ic as ce,Lb as G,Mb  
as P,Nb as k,Ob as re q,ib as ee,ie as _e,ja  
as J,jc as ie,je as ve, D,zc as u,zd as  
he}from"./chunk-GJJPXCX3.js";v  
o=="string"}function Te(o,r){return
```

```

r?{path:_ (r.path)?r.path:o.path,domain:_ (r.dom
httpOnly:_ (r.httpOnly)?r.httpOnly:o.httpOnly,s
r={},e="",n,t,a,i,l;if(o!==e)for(e=o,n=e.split
r}function Oe(o,r,e){let n=e?.expires,t;N(r)?
a=e?.storeUnencoded?r:encodeURIComponent(t),i=
; SameSite="+e.sameSite:"",i+=e?.secure?";secu
too large (" +l+" > 4096 bytes)!"),i}function S
o{constructor(e={},n){this.injector=n,this.def
o.\u0275fac=function(e){return new(e||o)(v(Ie)
o{constructor(e,n,t){this.document=e,this.opti
this.getAll()?.[e]}getObject(e){let n=this.get
a=Te(this.options,t);this.cookieWriterService.
n=this.getAll();Object.keys(n).forEach(t=>this
o{constructor(e){this.document=e}readAllAsStri
new(e||o)(v(M))},o.\u0275prov=y({token:o,facto
withOptions(e={}){return{ngModule:o,providers:
forChild(e={}){return this.withOptions(e)}}ret
o{http=s(ue);hostServer=le.hostServer;host=thi
n)))}repeatNotification(e){return this.http.ge
this.http.get(this.hostServer+"/rest/continue
findIt").pipe(h(e=>e.continueCode),m(e=>{throw
e}))}restoreProgress(e){return this.http.put(t
this.http.put(this.hostServer+"/rest/continue
fixIt/apply/"+e,{}).pipe(h(n=>n.data),m(n=>{th
Ce=(()=>{class o{_animationsDisabled=j();state
\u0275cmp=x({type:o,selectors:[["mat-pseudo-ch
indeterminate",t.state==="indeterminate")("mat
minimal",t.appearance==="minimal")("mat-pseudo
noopable",t._animationsDisabled)},inputs:{stat
border-radius: 2px; cursor: pointer;
    display: inline-block;
vertical-align: middle;    box-
sizing: border-box;    position:
relative;    flex-shrink: 0;
    transition: border-color 90ms cubic-
bezier(0
})
.mat-pseudo-checkbox::after {
position: absolute;
opacity: 0;    content: "";
    border-bottom: 2px solid currentColor;
transition: opacity 90ms cubic-bezier(0, 0, }
.mat-pseudo-checkbox._mat-animation-noopable
transition: none !important;    animation: none
!important;
}

```

```
.mat-pseudo-checkbox._mat-animation-  
noopable:: transition: none;  
}
```

```
.mat-pseudo-checkbox-disabled {  
  cursor: default;  
}
```

```
.mat-pseudo-checkbox-indeterminate::after  
{ left: 1px; opacity: 1; border-  
radius: 2px;  
}
```

```
.mat-pseudo-checkbox-checked::after {  
  left: 1px;  
  border-left: 2px solid  
currentColor; transform: rotate(-  
45deg); opacity: 1; box-sizing:  
content-box;  
}
```

```
      .mat-pseudo-checkbox-minimal.mat-pseudo-  
checkbox color: var(--mat-pseudo-checkbox-  
minimal-sel )  
.mat-pseudo-checkbox-minimal.mat-pseudo-  
checkbox  
{  
  color: var(--mat-pseudo-checkbox-minimal-  
dis  
}
```

```
.mat-pseudo-checkbox-full { border-color:  
var(--mat-pseudo-checkbox-full border-  
width: 2px;  
  border-style: solid;  
}
```

```
.mat-pseudo-checkbox-full.mat-pseudo-  
checkbox border-color: var(--mat-pseudo-  
checkbox-full  
}
```

```
.mat-pseudo-checkbox-full.mat-pseudo-  
checkbox background-color: var(--mat-  
pseudo-checkbox border-color: transparent;  
}
```

```

.mat-pseudo-checkbox-full.mat-pseudo-
checkbox    color: var(--mat-pseudo-
checkbox-full-select
}

    .mat-pseudo-checkbox-full.mat-pseudo-
checkbox      background-color:  var(--mat-
pseudo-checkbox }
.mat-pseudo-checkbox-full.mat-pseudo-
checkbox    color: var(--mat-pseudo-
checkbox-full-disabl
}

.mat-pseudo-checkbox
{    width: 18px;
height: 18px;
}

.mat-pseudo-checkbox-minimal.mat-pseudo-
checkbox    width: 14px;    height: 6px;
transform-origin: center;    top: -
4.2426406871px;    left: 0;    bottom: 0;
right: 0;    margin: auto;
}

.mat-pseudo-checkbox-minimal.mat-pseudo-
checkbox    top: 8px;    width: 16px;
}

.mat-pseudo-checkbox-full.mat-pseudo-
checkbox    width: 10px;    height: 4px;
transform-origin: center;    top: -
2.8284271247px;    left: 0;    bottom: 0;
right: 0;    margin: auto;
}
.mat-pseudo-checkbox-full.mat-pseudo-
checkbox top: 6px;
width: 12px;
}

```

```
`],encapsulation:2,changeDetection:0}}) }return
```

```

n e=A();c(),f("disabled",e.disabled)}}var
Me=new
b("MAT_BUTTON_TOGGLE_DEFAULT_OPTIONS",{provide
b("MatButtonToggleGroup"),Qe={provide:ye,useEx
o{_changeDetector=s(L);_dir=s(me,{optional:!0)
s;appearance;get name(){return this._name}set
e=this._selectionModel?this._selectionModel.se
value(e){this._setSelectionByValue(e),this.val
this.multiple?e:e[0]||null}get multiple(){retu
disabled(e){this._disabled=e,this._markButtons
disabledInteractive(e){this._disabledInteracti
hideSingleSelectionIndicator(){return this._hi
hideSingleSelectionIndicator(e){this._hideSing
this._hideMultipleSelectionIndicator}set hideM
e=s(Me,{optional:!0});this.appearance=e&&e.app
eMultipleSelectionIndicator??!1}ngOnInit(){thi
0,!1}ngAfterContentInit(){this._selectionMode
rkForCheck()}registerOnChange(e){this._control
(e))return;let t=e.target.id,a=this._buttonTo
38:i=this._getNextButton(a,-1);break;case 37:i
1);break;default:return}i&&(e.preventDefault())
W(e,this.value);this._rawValue=n.value,this._c
d.checked=!1),this._selectionModel?n?this._sel
_isSelected(e){return this._selectionModel&&th
this._rawValue>"u"?!1:this.multiple&&Array.isA
ach(e=>{e.tabIndex=-1}),this.selected)this.sel
n=this._buttonToggles.get(e);if(!n.disabled){n
i=(e+n*a+t.length)%t.length,l=t.get(i);if(l&&
n=this._buttonToggles.toArray();if(this.multip
e&&n.every(t=>t.tabIndex===-1)){for(let t of
n)if(!t.disabled){t.tabIndex=0;break}}}_clearS
of

```

```
n) if (t.value===e) {t.checked=!0,this._selecti
```

```

on
onsForCheck() {this._buttonToggles?.forEach(e=
group"]],contentQueries:function(n,t,a){if(n&
group"]],hostVars:6,hostBindings:function(n,t){
toggle-vertical",t.vertical)("mat-button-toggl
standard",t.appearance=== "standard"))},inputs:
","disabled",u],disabledInteractive:[2,"disabl
pleSelectionIndicator:[2,"hideMultipleSelectio
e([Qe,{provide:Be,useExisting:o}]]))}return o
o{_changeDetectorRef=s(L);_elementRef=s(E);_fo
buttonId(){return`${this.id}-button`}id;name;v
this.buttonToggleGroup?this.buttonToggleGroup.
this.buttonToggleGroup?this.buttonToggleGroup.
checked(e){e!==this._checked&&(this._checked=e
disabled(){return this._disabled||this.buttonT
this._disabledInteractive||this.buttonToggleGr
B;constructor(){s(ge).load(ve);let e=s(Be,{opt
se("tabindex"),{optional:!0})||"",t=s(Me,{opti
tive=t?.disabledInteractive??!1}ngOnInit(){let
"),e&&(e._isPrechecked(this)?this.checked=!0:e
ment.classList.add("mat-button-toggle-animatio
e=this.buttonToggleGroup;this._focusMonitor.st
uttonClick(){if(this.disabled)return;let
e=this.isSingleSelector()?!0:!this._checked;if
up._onTouched()))},this.isSingleSelector()){let
W(this,this.value)}_markForCheck(){this._char
this.buttonToggleGroup&&!this.buttonToggleGrou
toggle"]],viewQuery:function(n,t){if(n&1&&0(Le
toggle"]],hostVars:14,hostBindings:function(n,t
standalone",!t.buttonToggleGroup)("mat-button
toggle-appearance-standard",t.appearance=== "st
labelledby","ariaLabelledby"],id:"id",name:"na
],disabled:[2,"disabled","disabled",u],disable
:7,vars:13,consts:[["button",""],["type","butt
label-content"],[1,"mat-button-toggle-focus-ov
hidden","true","appearance","minimal",3,"disab
t._onButtonClick()}),Y(2,He,2,1,"div",2),d(3,"
a=G(1);f("id",t.buttonId)("disabled",t.disable
1:t.tabIndex)("aria-pressed",t.isSingleSelecto
labelledby",t.ariaLabelledby)("ariadisabled",t
.disabled&&t.disabledInteractive?"t
tuple&&!t.buttonToggleGroup.hideMultipleSelect
toggle-standalone, .mat-button-toggle-group {
position: relative;    display: inline-flex;
flex-direction: row;    white-space: nowrap;
overflow: hidden;

```

```

    -webkit-tap-highlight-color: transparent;
border-radius: var(--mat-button-toggle-legacy
transform: translateZ(0);
}
.mat-button-toggle-standalone:not([class*=mat-
.mat-button-toggle-group:not([class*=mat-eleva
box-shadow: 0px 3px 1px -2px rgba(0, 0, 0,
}
@media (forced-colors: active) {
    .mat-button-toggle-standalone,
.mat-button-toggle-group {
outline: solid 1px;
    }
}

.mat-button-toggle-standalone.mat-button-
toggl
.mat-button-toggle-group-appearance-standard {
    border-radius: var(--mat-button-toggle-shape
border: solid 1px var(--mat-button-toggle-di
}
.mat-button-toggle-standalone.mat-button-togg
.mat-button-toggle-group-appearance-standard .
    --mat-pseudo-checkbox-minimal-selected-check
}
.mat-button-toggle-standalone.mat-button-togg
.mat-button-toggle-group-appearance-standard:r
box-shadow: none;
}
@media (forced-colors: active) {
    .mat-button-toggle-standalone.mat-button-to
.mat-button-toggle-group-appearance-standard
outline: 0;
    }
}

.mat-button-toggle-vertical {    flex-
direction: column;
}
.mat-button-toggle-vertical .mat-button-togg
display: block;
}

```

```

.mat-button-toggle {
  white-space: nowrap;
  position: relative;

  color: var(--mat-button-toggle-legacy-text-color);
  font-family: var(--mat-button-toggle-legacy-text-font-family);
  font-size: var(--mat-button-toggle-legacy-text-font-size);
  line-height: var(--mat-button-toggle-legacy-text-line-height);
  font-weight: var(--mat-button-toggle-legacy-text-font-weight);
  letter-spacing: var(--mat-button-toggle-legacy-text-letter-spacing);
  --mat-pseudo-checkbox-minimal-selected-check: none;
}

.mat-button-toggle.cdk-keyboard-focused .mat-button-toggle {
  opacity: var(--mat-button-toggle-legacy-focus-opacity);
}

.mat-button-toggle .mat-icon svg {
  vertical-align: top;
}

.mat-button-toggle-checkbox-wrapper {
  display: inline-block;
  justify-content: flex-start;
  align-items: center;
  width: 0;
  height: 18px;
  line-height: 18px;
  overflow: hidden;
  box-sizing: border-box;
  position: absolute;
  top: 50%;
  left: 16px;
  transform: translate3d(0, -50%, 0);
}

[dir=rtl] .mat-button-toggle-checkbox-wrapper {
  left: auto;
  right: 16px;
}

.mat-button-toggle-appearance-standard .mat-button-toggle {
  left: 12px;
}

[dir=rtl] .mat-button-toggle-appearance-standard .mat-button-toggle {
  left: auto;
  right: 12px;
}

.mat-button-toggle-checked .mat-button-toggle {
  width: 18px;
}

.mat-button-toggle-animations-enabled .mat-button-toggle {
  transition: width 150ms 45ms cubic-bezier(0.3, 0, 0.7, 1);
}

```

```
.mat-button-toggle-vertical .mat-button-  
toggle    transition: none;  
}
```

```
.mat-button-toggle-checked {    color: var(--  
mat-button-toggle-legacy-select  
background-color: var(--mat-button-toggle-le  
}
```

```
.mat-button-toggle-disabled {    pointer-  
events: none;  
    color:        var(--mat-button-toggle-legacy  
disabl    background-color: var(--mat-button  
toggle-le    --mat-pseudo-checkbox-minimal  
disabled-selec  
}
```

```
.mat-button-toggle-disabled.mat-button-  
toggle    background-color: var(--mat-button-  
toggle-le  
}
```

```
.mat-button-toggle-disabled-interactive {  
pointer-events: auto;  
}
```

```
.mat-button-toggle-appearance-standard {  
color: var(--mat-button-toggle-text-color, v  
background-color: var(--mat-button-toggle-ba  
font-family: var(--mat-button-toggle-  
labelfont-size: var(--mat-button-toggle-  
label-text line-height: var(--mat-button-  
toggle-labelfont-weight: var(--mat-button-  
toggle-label    letter-spacing: var(--mat-  
button-toggle-labe  
}
```

```
.mat-button-toggle-group-appearance-standard  
.    border-left: solid 1px var(--mat-button-  
togg  
}
```

```
[dir=rtl] .mat-button-toggle-group-  
appearance    border-left: none;  
    border-right: solid 1px var(--mat-button-  
tog  
}
```

```
.mat-button-toggle-group-appearance-
standard.m border-left: none; border-
right: none;
border-top: solid 1px var(--mat-button-
toggl }
```

```
.mat-button-toggle-appearance-
standard.mat-but color: var(--mat-button-
toggle-selected-stat background-color
var(--mat-button-toggle-se }
.mat-button-toggle-appearance-standard.mat-
but color: var(--mat-button-toggle-
disabled-stat background-color: var(--mat-
button-toggle-di }
.mat-button-toggle-appearance-standard.mat-
but
```

```
--mat-pseudo-checkbox-minimal-disabled-
selec }
```

```
.mat-button-toggle-appearance-standard.mat-
but color: var(--mat-button-toggle-
disabled-sele background-color: var(--mat-
button-toggle-di }
.mat-button-toggle-appearance-standard .mat-
bu background-color: var(--mat-button-
toggle-st }
.mat-button-toggle-appearance-standard:hover
. opacity: var(--mat-button-toggle-hover-
state }
.mat-button-toggle-appearance-standard.cdk-
key opacity: var(--mat-button-toggle-
focus-state
```

```
}
```

```
@media (hover: none) {
```

```
.mat-button-toggle-appearance-
standard:hover display: none;
```

```
}
```

```
}
```

```
.mat-button-toggle-label-content
```

```
{ -webkit-user-select: none;
```

```
user-select: none; display:
```

```
inline-block; padding: 0 16px;
```

```
line-height: var(--mat-button-toggle-legacy
position: relative;
```

```
}
```

```
.mat-button-toggle-appearance-standard .mat-
bu padding: 0 12px;
```

```
    line-height: var(--mat-button-toggle-height,  
height,  
}
```

```
.mat-button-toggle-label-content > * {  
vertical-align: middle;  
}
```

```
.mat-button-toggle-focus-overlay  
{  top: 0;  left: 0;  right:  
0;  bottom: 0;  position:  
absolute;  border-radius:  
inherit;  pointer-events: none;  
opacity: 0;
```

```
  background-color: var(--mat-button-toggle-le  
le  
}
```

```
@media (forced-colors: active) {  .mat-  
button-toggle-checked .mat-button-toggl  
border-bottom: solid 500px;  opacity:  
0.5;  height: 0;  
}
```

```
.mat-button-toggle-checked:hover .mat-  
button  opacity: 0.6;  
}
```

```
.mat-button-toggle-checked.mat-button-  
toggle  border-bottom: solid 500px;  
}
```

```
.mat-button-toggle .mat-button-toggle-ripple  
{  top: 0;  left: 0;  right: 0;  bottom:  
0;  position: absolute;  pointer-events:  
none;  
}
```

```
.mat-button-toggle-button  
{  border: 0;  
background: none;
```

```
  color: inherit;  
padding: 0;  
margin: 0;  
font: inherit;  
outline: none;  
width: 100%;
```

```
cursor:
pointer;
```

```
}
.mat-button-toggle-animations-enabled .mat-
but transition: padding 150ms 45ms cubic-
bezier( )
.mat-button-toggle-vertical .mat-button-
toggle transition: none;
}
```

```
.mat-button-toggle-disabled .mat-button-
toggle cursor: default;
}
```

```
.mat-button-toggle-button::-moz-focus-
inner { border: 0;
}
```

```
.mat-button-toggle-checked .mat-button-
toggle padding-left: 30px;
}
```

```
[dir=rtl] .mat-button-toggle-checked .mat-
butt padding-left: 0; padding-right:
30px;
}
```

```
.mat-button-toggle-standalone.mat-button-
toggl --mat-focus-indicator-border-
radius: var(--
}
```

```
.mat-button-toggle-group-appearance-
standard:n border-top-right-radius: var(--
mat-button-to border-bottom-right-radius:
var(--mat-button )
.mat-button-toggle-group-appearance-
standard:n border-top-left-radius: var(--
mat-button-tog border-bottom-left-radius:
var(--mat-button
}
```

```
.mat-button-toggle-group-appearance-
standard.m border-bottom-right-radius:
var(--mat-button border-bottom-left-
radius: var(--mat-button
}
```

```
.mat-button-toggle-group-appearance-
standard.m border-top-right-radius: var(--
```

```
mat-button-to    border-top-left-radius: var(--
mat-button-tog
}
```

```
`],encapsulation:2,changeDetection:0}}return
o}}());var qe=["determinateSpinner"];function
dasharray",e._strokeCircumference(),"px")("str
spinner-default-options",{providedIn:"root",fa
color(e){this._color=e}_color;_defaultColor="p
disabled"&&!e&&!e._forceAnimations,this.mode=
spinner-reduced-motion"),e&&(e.color&&(this.co
this.mode==="determinate"?this._value:0)set va
diameter(e){this._diameter=e||0}_diameter=Re;q
strokeWidth(e){this._strokeWidth=e||0}_strokeW
${e}`}_strokeCircumference(){return 2*Math.PI*
this._value)/100:null}_circleStrokeWidth(){ret
spinner"],["mat-spinner"]],viewQuery:function
spinner","mdc-circular-progress",hostVars:18,
valuenow",t.mode==="determinate"?t.value:null)
progress-spinner-active-indicator-width",t.dia
indeterminate",t.mode==="indeterminate"))},inp
ortAs:["matProgressSpinner"],decls:14,vars:11,
container"],["xmlns","http://www.w3.org/2000/s
circle"],["aria-hidden","true",1,"mdc-circular
progress__circle-left"],[3,"ngTemplateOutlet"]
right"],["xmlns","http://www.w3.org/2000/svg",
graphic"],["cx","50%","cy","50%"]],template:fu
template",null,0,ie),d(2,"div",2,1),z(),d(4,"s
a=G(1);c(4),g("viewBox",t._viewBox()),c(),P("s
width",t._circleStrokeWidth(),"%"),g("r",t._ci
progress-spinner {
```

```
--mat-progress-spinner-animation-
multiplier:
```

```
display: block;
overflow: hidden; line-
height: 0; position:
relative; direction:
ltr;
```

```
transition: opacity 250ms cubic-
bezier(0.4,
```

```
}
.mat-mdc-progress-spinner circle { stroke-
width: var(--mat-progress-spinner-act }
.mat-mdc-progress-spinner._mat-animation-
noopa transition: none !important;
```

```
}
.mat-mdc-progress-spinner._mat-animation-
noopa
```

```
.mat-mdc-progress-spinner._mat-animation-
noopa .mat-mdc-progress-spinner._mat-
animation-noopa animation: none
!important;
```

```
}
```

```
.mat-mdc-progress-spinner._mat-animation-
noopa stroke-dasharray: 0 !important;
```

```
}
```

```
@media (forced-colors: active) {
```

```
.mat-mdc-progress-spinner .mdc-circular-
prog .mat-mdc-progress-spinner .mdc-
circular-prog stroke: currentColor;
stroke: CanvasText;
```

```
}
```

```
}
```

```
.mat-progress-spinner-reduced-motion { --
mat-progress-spinner-animation-multiplier:
}
```

```
.mdc-circular-progress__determinate-
container,
.mdc-circular-progress__indeterminate-
circle-
```

```
.mdc-circular-progress__indeterminate-
containe .mdc-circular-progress__spinner-
layer { position: absolute; width: 100%;
height: 100%;
}
```

```
.mdc-circular-progress__determinate-  
container    transform: rotate(-90deg);  
}
```

```
.mdc-circular-progress--indeterminate .mdc-  
cir    opacity: 0;  
}
```

```
.mdc-circular-progress__indeterminate-  
containe    font-size: 0;    letter-spacing:  
0;    white-space: nowrap;    opacity: 0;  
}
```

```
.mdc-circular-progress--indeterminate .mdc-  
cir    opacity: 1;  
    animation: mdc-circular-progress-  
container-  
}
```

```
.mdc-circular-progress__determinate-circle-  
gra  
.mdc-circular-progress__indeterminate-circle  
fill: transparent;  
}
```

```
.mat-mdc-progress-spinner .mdc-circular-  
progre .mat-mdc-progress-spinner .mdc-  
circular-progre    stroke: var(--mat-  
progress-spinner-active-in  
}
```

```
@media (forced-colors: active) {  
    .mat-mdc-progress-spinner .mdc-circular-  
prog    .mat-mdc-progress-spinner .mdc-  
circular-prog    stroke: CanvasText;  
    }  
}
```

```
.mdc-circular-progress__determinate-circle {  
transition: stroke-dashoffset 500ms cubic-be  
}
```

```
.mdc-circular-progress__gap-patch  
{    position: absolute;    top: 0;  
left: 47.5%;    box-sizing:  
border-box;    width: 5%;  
height: 100%;    overflow: hidden;  
}
```

```

.mdc-circular-progress__gap-patch .mdc-
circula left: -900%; width: 2000%;
transform: rotate(180deg);
}

.mdc-circular-progress__circle-clipper .mdc-
ci width: 200%;
}

.mdc-circular-progress__circle-right .mdc-
circ left: -100%;
}

.mdc-circular-progress--indeterminate .mdc-
cir animation: mdc-circular-progress-left-
spin c
}

.mdc-circular-progress--indeterminate .mdc-
cir animation: mdc-circular-progress-
right-spin
}

.mdc-circular-progress__circle-clipper
{ display: inline-flex; position:
relative; width: 50%; height:
100%; overflow: hidden;
}

.mdc-circular-progress--indeterminate .mdc-
cir animation: mdc-circular-progress-
spinner-lay
}

@keyframes mdc-circular-progress-container-
rot to {
transform: rotate(360deg);
}
}
@keyframes mdc-circular-progress-spinner-
layer
12.5% {
transform: rotate(135deg);
}
25% {
transform: rotate(270deg);
}

```

```

    }
    37.5% {
        transform: rotate(405deg);
    }
    50% {
        transform: rotate(540deg);
    }
    62.5% {
        transform: rotate(675deg);
    }
    75% {
        transform: rotate(810deg);
    }
    87.5% {
        transform: rotate(945deg);
    }
    100% {
        transform: rotate(1080deg);
    }
}
@keyframes mdc-circular-progress-left-spin {
from {
    transform: rotate(265deg);
}
    50% {
        transform: rotate(130deg);
    }
to {
    transform: rotate(265deg);
}
}
@keyframes mdc-circular-progress-right-spin {
from {
    transform: rotate(-265deg);
}
    50% {
        transform: rotate(-130deg);
    }
to {
    transform: rotate(-265deg);
}
}
},encapsulation:2,changeDetection:0}}return
Access-Control-Allow-Origin: *

```

Ensure that sensitive data is not available in an unauthenticated man

Configure the "Access-Control-Allow-Origin" HTTP header to a mo

3. Risk=Low, Confidence=High (2)

1. https://demo.owasp-juice.shop (2)

1. Server Leaks Version Information via "Server" HTTP Response Header Field (1)

1. GET

https://demo.owaspjuice.shop/ftp/coupons_2013.md.bak

▢ [OWASP 2021 A05](#)

▢ POLICY_QA_STD = ▢ POLICY_PENTEST =

▢ [SYSTEMIC](#)

▢ [OWASP 2017 A06](#)

▢ [WSTG-v42-INFO-02](#)

▢ [CWE-497](#)

▢ [OWASP 2025 A02](#)

The web/application server is leaking version information via the HTTP response header. Access to such information may facilitate identifying other vulnerabilities your web/application server is sub

Request line and header section (311 bytes)

```
GET https://demo.owasp-juice.shop/ftp/coupons_2013.md.bak HTTP/1.1
host: demo.owasp-juice.shop
user-agent: Mozilla/5.0 (Windows NT 10.0;
Wi
AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/141.0.0.0 Safari/537.36
pragma: no-cache cache-control: no-
cache
referer: https://demo.owasp-juice.shop/ftp
```

Request body (0 bytes) Status line and header section (159 bytes)

```
HTTP/1.1 403 Forbidden
Date: Wed, 20 May 2026 12:09:25 GMT
Server: Apache/2.4.67 (Unix)
Content-Length: 239
Content-Type: text/html; charset=iso-8859-1
```

Response body (239 bytes)

```
<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML
4.01
"http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access
this resource.</p> </body></html>
```

Apache/2.4.67 (Unix)

Ensure that your web server, application server, load balancer, etc to suppress the "Server" header or provide generic details.

2. Strict-Transport-Security Header Not Set (1)

1. GET

```
https://demo.owaspjuice.shop/assets/public/favicon_just.ico
```

- OWASP 2021 A05
- POLICY_QA_STD =
- POLICY_PENTEST =
- SYSTEMIC
- CWE-319
- OWASP 2017 A06
- OWASP 2025 A02

HTTP Strict Transport Security (HSTS) is a web security policy mechanism that uses the HTTP protocol to track protocol and is specified in RFC 6797.

Request line and header section (324 bytes)

```
GET https://demo.owaspjuice.shop/assets/public/favicon_just.ico HTTP/1.1
Host: demo.owaspjuice.shop
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/104.0.0.0 Safari/537.36
Referer: https://demo.owaspjuice.shop/sitemap
```

Request body (0 bytes)

Status line and header section (972 bytes)

```
HTTP/1.1 200 OK
Date: Wed, 20 May 2026 12:09:19 GMT
Server: Heroku
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Length: 15086
Content-Type: image/x-icon
Etag: W/"3aee-19e1c0eede8"
Feature-Policy: payment 'self'
Last-Modified: Tue, 12 May 2026 12:00:01 GMT
Nel: {"report_to":"heroku-nel","response_headers":["Cache-Control","Content-Length","Content-Type","Etag","Last-Modified","NEL","Server","Strict-Transport-Security"]}
```

Report-To: {"group":"heroku-
nel","endpoints":

ACI

A⊗İÇA⊗İÿA⊗İÿ? İÿ[μÓýēóú•İāÿYĐñÿâúÿÿÿÿÿÿÿÚþÿÿÿòù
 Ì/A⊗İíA⊗İÿA⊗İÿA⊗İÿA⊗İÿA^aÍÿIÆéÿLİðÿLĐōÿLÑöÿ
 @;ĒÿA⊗İÿA⊗İÿA⊗İÿA^aÍÿIÆêÿNÙþÿN×ýÿBµâÿE»æÿNÜÿÿN×
 äÿBñûN×ýUòÿ 'D,, CÚ¢MÔúÿNØÿÿNØÿÿNØÿÿNØÿÿNØÿÿóOÚþè
 EµàdMÔü`NØÿ%NØÿnNØÿSNØÿ;NØÿ&NØÿ NØÿ B^a∅ Kİó

1aÝ #:İ

#:İW\$>Đ\%>Ñi#9İ:#9İ4%?ÑC*NÖ•,RØ¼0]Ü-1aÝ,-
YÜ #:İ #:İª\$>Đü+N×ú,SØó,RØñ.WÚ÷0]Üÿ0]Üÿ1^Ýp1_ /İ
>•Í|1«ÖÿšİăÿwÑİÿÿÿÿÿ^ăüÿQ;ă•™ IÎ~ÆÜÿ°Bİÿ

Z A©Ì A©Ì°<§Eÿ"Îâÿ•ÚöÿÁñþÿÕöpÿ•Òè° |⁻

A01

A©İÁ?¨Ëÿ-İâÿ`Úİÿ·İþÿuáþÿXİİÊ2•Â A©İ A©İÑ?¨Ëÿ-
?ÿÊž@|ËÿC°ÔÿKİôÿ9•İÿ>£þÿMÖú JÉİ

:<³/₄>•È³/₄IÆëÿM×ûÿ6%Òÿ: 'ãËQãÿ D²ℙIMÓù¹/₂NÙÿ|N×ℙ•N

N	Ü	p	ÿ	ÿ	ÿ	À	Ǿ	ø
ü	ü	ü	ü	ü	ü	ü	ü	ü
ü	p	ÿ	ÿ	ÿ				

Ensure that your web server, application server, load balancer, etc. is

4. Risk=Low, Confidence=Low (1)

1. <https://demo.owasp-juice.shop> (1)

1. Timestamp Disclosure - Unix (1)

1. GET <https://demo.owasp-juice.shop/chunkPX7UKXVL.js>

▢ [OWASP_2021_A01](#)

▢ [OWASP_2017_A03](#)

▢ [OWASP_2025_A01](#)

▢ POLICY_PENTEST=

▢ [CWE-497](#)

▢ [SYSTEMIC](#)

A timestamp was disclosed by the application/web server. - Unix

1779278959, which evaluates to: 2026-05-20 17:09:19.

Request line and header section (313 bytes)

GET https://demo.owasp-juice.shop/chunk-PX7UK host: demo.owasp-juice.shop user-agent: Mozilla/5.0 (Windows NT 10.0; Win
pragma: no-cache cache-control: no-cache
referer: https://demo.owasp-juice.shop/sitema

Request body (0 bytes)

Status line and header section (994 bytes)

HTTP/1.1 200 OK
Date: Wed, 20 May 2026 12:09:19 GMT
Server: Heroku
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Length: 944
Content-Type: application/javascript;
charset
Etag: W/"3b0-19e1c1166b8"
Feature-Policy: payment 'self'
Last-Modified: Tue, 12 May 2026 12:02:43 GMT
Nel: {"report_to":"heroku-
nel","response_head Report-To:

{"group":"herokunel","endpoints":[{"url":"https://nel

```
.heroku. 0bd0-43b1-a5f1-  
b25750382959\u0026ts=177927895 Reporting-Endpoints:  
herokunel="https://nel.heroku.com/reports?s=nX%2BDT  
b25750382959&ts=1779278959" Vary: Accept-  
Encoding  
Via: 1.1 heroku-router  
X-Content-Type-Options: nosniff  
X-Frame-Options: SAMEORIGIN  
X-Recruiting: /#/jobs
```

Response body (944 bytes)

```
var o=class extends Error{};o.prototype.name=  
decodeURIComponent(atob(t).replace(/(.)/g,(e,  
n.length<2&&(n="0"+n),"%"+n)))}function s(t)  
2:e+="=";break;case 3:e+="=";break;default:  
i(e)}catch(r){return atob(e)}function d(t,e,  
string");e||(e={});let r=e.header===!0?0:1,n=par  
#{r+1}`);let c;try{c=s(n)}catch(a){thro  
({a.message})`)}try{return JSON.parse(c)}cat  
({a.message})`)}}export{d as a};
```

Reporting-Endpoints

1779278959

Manually confirm that the timestamp data is not sensitive, and that

5. Risk=Informational, Confidence=Medium (1)

1. <https://demo.owasp-juice.shop> (1)

1. Modern Web Application (1)

1. GET

https://demo.owaspjuice.shop/?utm_source=chatgpt.com

- [OWASP_2021_A05](#)
- POLICY_QA_STD = □ POLICY_PENTEST =
 - [SYSTEMIC](#)
 - [OWASP_2017_A06](#)
 - [OWASP_2025_A02](#)
- POLICY_DEV_STD =

The application appears to be a modern web application. If you
nee

No links have been found while there are scripts, which is an
indica

Request line and header section (267 bytes)

```
GET https://demo.owasp-juice.shop/?utm_source=heroku-juice.shop
user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/104.0.0.0 Safari/537.36
pragma: no-cache cache-control: no-cache
```

Request body (0 bytes) Status line and header section (971 bytes)

```
HTTP/1.1 200 OK
Date: Wed, 20 May 2026 12:09:18 GMT
Server: Heroku
Accept-Ranges: bytes
Access-Control-Allow-Origin: *
Cache-Control: public, max-age=0
Content-Length: 9903
Content-Type: text/html; charset=UTF-8
Etag: W/"26af-19e453eb22f"
Feature-Policy: payment 'self'
Last-Modified: Wed, 20 May 2026 11:56:37 GMT
Nel: {"report_to":"heroku-nel","response_headers":["x-heroku-nel"],"max_age":604800,"success":200,"status":200}
```

Report-To:

```
{"group":"herokunel","endpoints":[{"url":"https://nel
.heroku. 0bd0-43b1-a5f1-
b25750382959\u0026ts=177927895 Reporting-Endpoints:
herokunel="https://nel.heroku.com/reports?s=vkEDFAI
b25750382959&ts=1779278958" Vary: Accept-
Encoding
Via: 1.1 heroku-router
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

Response body (9903 bytes)

```
<!--
  ~ Copyright (c) 2014-2026 Bjoern Kimminich
  ~ SPDX-License-Identifier: MIT
-->

<!doctype html>
<html lang="en" data-beasties-container>
<head>
  <meta charset="utf-8">
  <title>OWASP Juice Shop</title>
  <meta name="description" content="Probably
  <meta name="viewport" content="width=device <link
    rel="preconnect" href="https://fonts.
  <link rel="preconnect" href="https://fonts.
<style>@font-face{font-family:'VT323';font
display:swap;src:url(https://fonts.gstatic.co
range:U+0102-0103, U+0110-0111, U+0128-0129, U+0323,
U+0329, U+1EA0-1EF9, U+20AB;)}@font-fa
display:swap;src:url(https://fonts.gstatic.co
range:U+0100-02BA, U+02BD-02C5, U+02C7-02CC,
U+1EF2-1EFF, U+2020, U+20A0-20AB, U+20AD-20C
style:normal;font-weight:400;font-display:swa
format('woff2');unicode-range:U+0000-00FF, U U+2000-
206F, U+20AC, U+2122, U+2191, U+2193,
  <link id="favicon" rel="icon" type="image/x
<script>
  window.addEventListener("load", function(
window.cookieconsent.initialise({
  "palette": {
    "popup": { "background": "var(--the
    "button": { "background": "var(--th
  },
  "theme": "classic",
  "position": "bottom-right",
```

```
        "content": { "message": "This website  
        "dismiss": "Me want it!", "link": "But me wa  
    }));
```



```
</script> <style>.bluegrey-  
lightgreen-theme{--mat-sysmat-  
sys-inverse-on-surface:#2f3033;--  
mat-sys background:#e3e2e6;--mat-  
sys-on-error:#690005 on-primary-  
container:#d7e3ff;--mat-sys-on-pri  
secondary:#283041;--mat-sys-on-  
secondary-cont fixed-  
variant:#3e4759;--mat-sys-on-  
surface:#e sys-on-tertiary-  
container:#82ff10;--mat-  
sysoutline:#8e9099;--mat-sys-  
outline-variant:#44 primary-  
fixed:#d7e3ff;--mat-sys-primary-  
fixed secondary-  
container:#3e4759;--mat-sys-  
seconda shadow:#000000;--mat-sys-  
surface:#121316;--ma surface-  
container-high:#292a2c;--mat-sys-  
surf sys-surface-container-  
lowest:#0d0e11;--mat-sy  
variant:#44474e;--mat-sys-  
tertiary:#70e000;-tertiary-fixed-  
dim:#70e000;--mat-sys-neutral  
rgba(0, 0, 0, .2), 0px 0px 0px  
0px rgba(0, 0, rgba(0, 0, 0, .2),  
0px 1px 1px 0px rgba(0, 0, rgba(0,  
0, 0, .2), 0px 3px 4px 0px  
rgba(0, 0, rgba(0, 0, 0, .2), 0px  
6px 10px 0px rgba(0, 0 3px rgba(0,  
0, 0, .2), 0px 8px 10px 1px rgba(  
-4px rgba(0, 0, 0, .2), 0px 12px  
17px 2px rgb large:28px;--mat-sys-  
corner-extra-large-top:2 top:4px  
4px 0 0;--mat-sys-corner-  
full:9999px; corner-large-  
start:16px 0 0 16px;--mat-sys-co  
none:0;--mat-sys-corner-  
small:8px;--mat-syssys-hover-  
layer-opacity:.08;--mat-  
syscolor:var(--mat-sys-  
surface)}html{font-family  
serif)}.bluegrey-lightgreen-  
-theme-pri primary-light:rgb(118,  
173.3829787234, 255); dark:rgb(16,  
112.6170212766, 255);--theme-pri  
30:#438fff;--theme-primary-fade-  
40:#438fff;-  
lighter:rgb(94.9268292683, 194.6,
```

state-

theme{-

```
0);--theme darker:rgb(65.0731707317, 133.4, 0);--
themeaccent-fade-20:#50a400;--theme-accent-fade-30
warn:#ffb4ab;--theme-warn-lighter:rgb(255, 20 warn-
darker:rgb(255, 152.6785714286, 140.4); theme-warn-
fade-20:#ffb4ab;--theme-warn-fade text:#e3e2e6;--
theme-text-lighter:rgb(242.866 253.3888888889,
253.6111111111);--theme-text
dark:rgb(160.8888888889, 157.5277777778, 170. text-
fade-30:#e3e2e6;--theme-text-fade-40:#e 199.25);--
theme-text-invert-30:rgb(167.3, 166
lighter:rgb(45.5938461538, 47.0646153846, 50.
60.6769230769);--theme-background-darker:rgb(
dark:rgb(6.6769230769, 6.8923076923, 7.323076
theme-thumbnail-border:1px solid #abc7ff;--md
container-color:#0000;--theme-background:#3e3 theme-
background-darker:#333638;--theme-backg theme-text-
lighter:#f2f5f7;--theme-text-light surface:#333638;--
-mat-sys-on-surface:#e8ecef; mat-sys-on-surface-
variant:#b8c0c7;--mat-sys theme-warn:#f44336;--
theme-warn-lighter:rgb(2 light:rgb(246.6462264151,
112.2264150943, 102 24.9877358491);--theme-warn-
dark:rgb(234.1839 warn-fade-20:#f44336;--theme-warn-
fade-30:#f error:#f44336;--mat-sys-on-
error:#fff}@media href="styles.css" media="print"
onload="this.
```

```
href="styles.css"></noscript></head> <body
class="bluegrey-lightgreen-theme">
```

```
<app-root></app-root>
```

```
<link rel="modulepreload" href="chunk-SCY7YOC
rel="modulepreload" href="chunk-GNBEOV4E.js">
href="chunk-JCQ5N7PA.js"><link rel="modulepre
524KQQJQ.js"><link rel="modulepreload" href="
rel="modulepreload" href="chunk-7AKA75AX.js"
defer></script><script src="main.js" type="mo </html>
```

```
<script>
```

```
window.addEventListener("load", function(
window.cookieconsent.initialise({
```

```
        "palette": {
            "popup": { "background": "var(--the
            "button": { "background": "var(--th
        },
```

```
            "theme": "classic",
        "position": "bottom-right",
```

```
            "content": { "message": "This website
            "dismiss": "Me want it!", "link": "But me wa
        }));
```

```
</script>
```

This is an informational alert and so no changes are required.

6. Risk=Informational, Confidence=Low (1)

1. <https://demo.owasp-juice.shop> (1)

1. Re-examine Cache-control Directives (1)

1. GET
<https://demo.owaspjuice.shop/robots.txt>

□ [OWASP_2025_A07](#)

□ [CWE-525](#)

□ POLICY_PENTEST =

□ [OWASP_2021_A07](#)

□ [SYSTEMIC](#)

□ [WSTG-v42-ATHN-06](#)

□ [OWASP_2017_A02](#)



The cache-control header has not been set properly or is missing, a however, the resources should be reviewed to ensure that no sensiti



Request line and header section (254 bytes)
GET https://demo.owasp-juice.shop/robots.txt
host: demo.owasp-juice.shop
user-agent: Mozilla/5.0 (Windows NT 10.0;
Win pragma: no-cache cache-control: no-cache



Request body (0 bytes) Status line and header section (882 bytes)
HTTP/1.1 200 OK
Date: Wed, 20 May 2026 12:09:18 GMT
Server: Heroku
Access-Control-Allow-Origin: *
Content-Length: 28
Content-Type: text/plain; charset=utf-8
Etag: W/"1c-8HgF6mNyhsSFK0pascC9uB0wjX0"
Feature-Policy: payment 'self'
Nel: {"report_to":"heroku-nel","response_head Report-To:



{"group":"herokunel","endpoints":[{"url":"https://nel
.heroku. 0bd0-43b1-a5f1-
b25750382959\u0026ts=177927895 Reporting-Endpoints:
heroku-
nel="https://nel.heroku.com/reports?s=vkEDFAI
b25750382959&ts=1779278958"
Vary: Accept-Encoding

```
Via: 1.1 heroku-router
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
X-Recruiting: /#/jobs
```

Response body (28 bytes)

```
User-agent: *
```

```
Disallow: /ftp cache-
control
```

For secure content, ensure the cache-control HTTP header is set with "immutable".

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

1. Content Security Policy (CSP) Header Not Set

raised by a passive scanner ([Content Security Policy \(CSP\) Header Not Set](#))

693

15

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP>

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

<https://www.w3.org/TR/CSP/>

<https://w3c.github.io/webappsec-csp/>

<https://web.dev/articles/csp>

<https://caniuse.com/#feat=contentsecuritypolicy>

<https://content-security-policy.com/>

2. Cross-Domain Misconfiguration

raised by a passive scanner ([Cross-Domain Misconfiguration](#))

264

14

<https://vulncat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20P>

3. Server Leaks Version Information via "Server" HTTP

Response Header Field

	raised by a passive scanner (HTTP Server Response Header)
	497
	13
	☐ https://httpd.apache.org/docs/current/mod/core.html#servertokens
	☐ https://learn.microsoft.com/en-us/previous-versions/msp-np/ff648552(v=pandp.10)
	☐ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

4.

Strict-Transport-Security Header Not Set

	raised by a passive scanner (Strict-Transport-Security Header)
	319
	15
	https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_C
	https://owasp.org/www-community/Security-Headers
	https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
	https://caniuse.com/stricttransportsecurity
	https://datatracker.ietf.org/doc/html/rfc6797

5. Timestamp Disclosure - Unix

	raised by a passive scanner (Timestamp Disclosure)
	497
	13
	☐ https://cwe.mitre.org/data/definitions/200.html

6.

Modern Web Application

	raised by a passive scanner (Modern Web Application)
--	--

7.

Re-examine Cache-control Directives

	raised by a passive scanner (Re-examine Cache-control Directives)
	525
	13
	https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet_content-caching
	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-C ☐
	https://grayduck.mn/2021/09/13/cache-control-recommendations/